Practical Exercise 1 - Threat Modeling

50 Points Possible

Due: Wed Oct 28, 2026 11:59pm

Attempt 1

In Progress

NEXT UP: Submit Assignment

Add Comment

2 Attempts Allowed

Available: Oct 6, 2026 3:30pm until Oct 28, 2026 11:59pm

Details

Reference Threat Model Document: Threat Model Document - Coffee Ordering Web App.pdf (https://dlsu.instructure.com/courses/269297/files/33470988?wrap=1)

Part 1 - Data Flow Diagrams and Threat Identification using STRIDE

For **each** of the data flows found in section 5.2 (pages 5-6) of the document:

1. Create a data flow diagram using OWASP Threat Dragon
2. Include trust boundaries (as indicated in section 5.1, page 5)
3. Indicate the threats to each component (as indicated in *Affected Components*, section 6, table 2, page 7). Each threat must have the following information:
   - Title (follow the *Threat Title* in table 2, page 7)
   - Type (follow the *STRIDE Category* in table 2, page 7)
   - Description (follow the *Threat Description* in table 2, page 7)
   - Severity - based on the number of mapped vulnerabilities (seen in table 3, page 8), counting the number of checks for each row:
     - LOW: 0-4 vulnerabilities
     - **MEDIUM**: 5-9 vulnerabilities
     - **HIGH**: 10-14 vulnerabilities
     - **CRITICAL**: 15-19 vulnerabilities

Course Chat

*Example: If a certain threat T-050 has 12 mapped vulnerabilities, its severity is **HIGH**. Likewise, if a threat* *is **LOW**.*

Ensure that all diagrams are in a single Threat Dragon project. For this part, the file to be submitted is (exported as PDF). As back-ups, submit also the screenshots of the data flow diagrams (jpg/png forma

Part 2 - Vulnerability Ranking and Prioritization using DREAD

For **each** of the vulnerabilities found in section 7, table 3, page 8 of the document, determine the scores using Exploitability, Affected Users, Discoverability). You will need access the CWE pages of these vulnerabilities provided in page 9 of the document. Alternatively, the link is https://cwe.mitre.org/data/definitions/x.html, w Example: The page for CWE-50 is **https://cwe.mitre.org/data/definitions/50.html (https://cwe.mitre.org/dat**

For this part, the file to be submitted is a matrix in spreadsheet file format or PDF. Is using Google Sh broken when you export the file.

Scoring guide:

- Each vulnerability will have a scoring weight. This is derived from the number of threats that each vulne of checks on a given column. *Example: If a certain vulnerability CWE-50 was mapped to threats T-060,*
- If a certain score cannot be obtained from the CWE page, assign a score of 10 instead.
- For the ranking, rank 1 is the vulnerability with the highest risk, and so on.

Damage Potential

Refer to the "Common Consequences" section of the CWE page. Count the number of unique impacts listed by counting each row in the table.



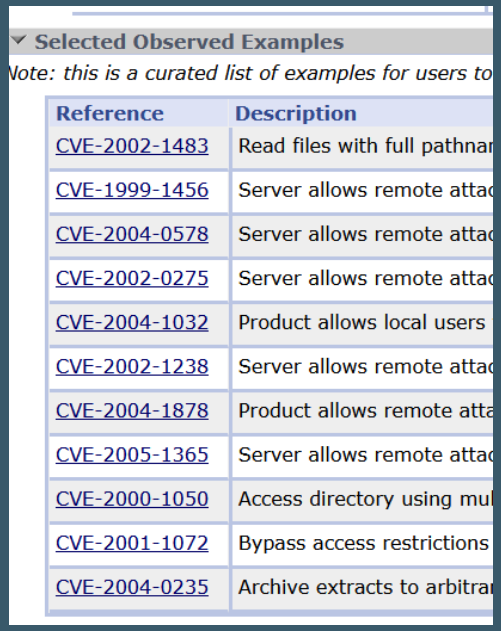
Damage Potential – Number of unique impacts under "Common Consequences" Table- "Impact" Colu

Chat is not connected.
Send

mn

Reproducibility

Refer to the "Selected Observed Examples" section of the CWE page.


Selected Observed Examples

Note: this is a curated list of examples for users to

Reference	Description
CVE-2002-1483	Read files with full pathnar
CVE-1999-1456	Server allows remote attac
CVE-2004-0578	Server allows remote attac
CVE-2002-0275	Server allows remote attac
CVE-2004-1032	Product allows local users
CVE-2002-1238	Server allows remote attac
CVE-2004-1878	Product allows remote atta
CVE-2005-1365	Server allows remote attac
CVE-2000-1050	Access directory using mul
CVE-2001-1072	Bypass access restrictions
CVE-2004-0235	Archive extracts to arbitrar

Reproducibility = Number of CVEs listed under "Selected Observed Samples" Table-"References" Column

Exploitability

Refer to the "Likelihood Of Exploit" section of the CWE page. Use 1 for Low, 5 for Medium, and 9 for High.


Likelihood Of Exploit

High

Exploitability = Likelihood of Exploit Value

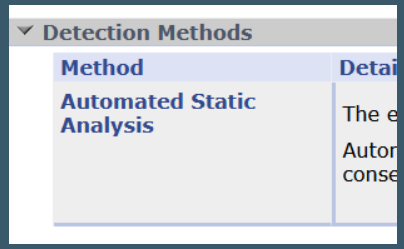
Affected Users

For this activity, assume that Affected Users always has the same score as Damage Potential.

Affected Users = Damage Potential

Discoverability

Refer to the "Detection Method" section of the CWE page.



Discoverability = Number of unique detection methods under the "Detection Methods" Table-"Method" Column

Risk (Weighted)

Overall Risk = Scoring Weight * Probability * Impact

where:

Probability = Reproducibility + Exploitability + Discoverability

and

Impact = Damage Potential + Affected Users

Sample Entry

Vulnerability	Scoring Weight	Damage Potential	Reproducibility	Exploitability	Affected Users	Discoverability	Probability	Impact	Overall Risk
CWE-73: External Control of File Name or Path (https://cwe.mitre.org/data/definitions/73.html)	5	6	3	9	6	1	13	12	780
CWE-202: Exposure of Sensitive Information Through Data Queries (https://cwe.mitre.org/data/definitions/202.html)	15	2	1	5	2	10	16	4	960

View Rubric

Practical Exercise 1 - Threat Modeling

Criteria	Ratings				Points
DFD Completeness	**Excellent** All 4 Data Flows from Section 5.2 are diagrammed correctly with proper direction. **5 pts**	**Very Good** 3 of 4 Data Flows are present, or all 4 are present but with minor direction errors. **4 pts**	**Needs Improvement** Only 1-2 Data Flows are present, or the logic is fundamentally wrong (e.g., circular flows). **2 pts**	**Missing** No diagrams provided. **0 pts**	/5 pts

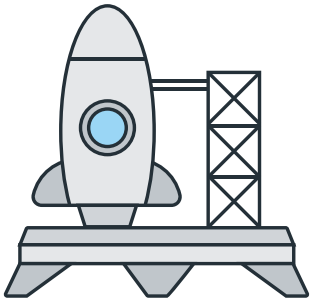
Criteria	Ratings				Points
Trust Boundaries	**Excellent** All 3 boundaries (Client/Server, Server/DB, Server/Payment) are clearly visible and correctly placed. **3 pts**	**Very Good** 2 boundaries are correct, or 1 is missing/misplaced. **2 pts**	**Needs Improvement** Only 1 boundary is shown, or boundaries are placed arbitrarily around safe components. **1 pts**	**Missing** No trust boundaries indicated. **0 pts**	/3 pts
Threat Mapping	**Excellent** Threats are attached to the exact components listed in Table 2. Titles, STRIDE Types, and Descriptions are copied exactly. **10 pts**	**Very Good** Most threats are correct, but 1-2 are attached to the wrong asset or have minor typos in the description. **8 pts**	**Needs Improvement** Threats are attached to random components (e.g., Database threats on the Client), or metadata does not match Table 2. **4 pts**	**Missing** No threats mapped. **0 pts**	/10 pts
Severity Logic	**Excellent** Severity (Low/Med/High/Critical) strictly follows the "Table 3 check-counting" rule for all entries. **7 pts**	**Very Good** Severity is mostly correct, but 1-2 entries have miscounts (e.g., counting a "Medium" as "High"). **5 pts**	**Needs Improvement** Severity seems guessed or randomized; does not correlate with the number of checks in Table 3. **3 pts**	**Missing** No severity ratings provided. **0 pts**	/7 pts
Scoring Weight	**Ex** Weights match the vertical column counts in Table 3 perfectly (e.g., CWE-20 = 7). **5 pts**	**Very Good** Weights are mostly accurate, but 1-2 columns were miscounted. **4 pts**	**Needs Improvement** Weights appear arbitrary (e.g., all set to "1") or do not reflect Table 3 inputs. **2 pts**	**Missing** Weight column missing. **0 pts**	/5 pts

Criteria	Ratings				Points
CWE Data Research	**Excellent** Scores for D/R/E/D are derived from valid CWE page data (Impact counts, Example counts, etc.). No "10s" used unless data is truly missing. **10 pts**	**Very Good** Generally correct, but student used "10" (default) for items where data actually exists on the CWE site. **8 pts**	**Needs Improvement** Scores are clearly made up (e.g., all 5s) and do not reflect the specific "Counting" rules in the instructions. **4 pts**	**Missing** No scoring matrix provided. **0 pts**	/10 pts
Risk Calculation	**Excellent** Formula applied correctly: Risk = Weight * (R+E+D) * (Damage + Affected Users). **5 pts**	**Very Good** Minor math errors in 1-2 rows, or "Affected Users" score was not set equal to "Damage" as requested. **4 pts**	**Needs Improvement** Wrong formula used (e.g., adding Weight instead of multiplying), resulting in wildly incorrect Risk scores. **2 pts**	**Missing** Risk not calculated. **0 pts**	/5 pts
Final Ranking	**Ex** Ranking is correct (Highest Risk = Rank 1 for all. **5 pts**	**Very Good** Ranking is correct (Highest Risk = Rank 1 for most. **3 pts**	**Needs Improvement** Ranking is correct (Highest Risk = Rank 1 for some. **2 pts**	**Missing** No ranking provided. **0 pts**	/5 pts

! Keep in mind, this submission will count for everyone in your Project Groups group.

Choose a submission type

Upload ARC More



Drag a file here, or

Choose a file to upload

or

Webcam Photo

Canvas Files